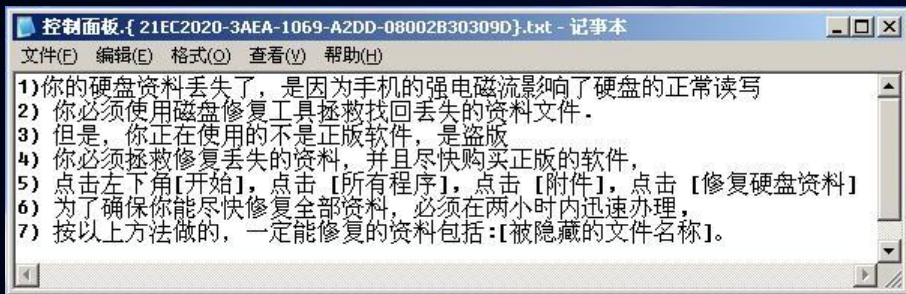


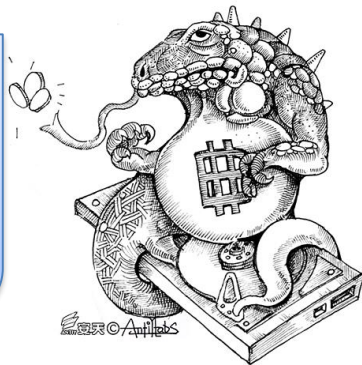
魔窟的水面之上和水面之下

安天 高喜宝

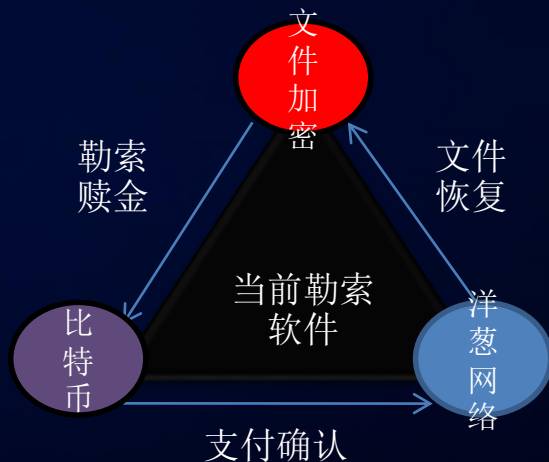
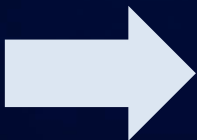
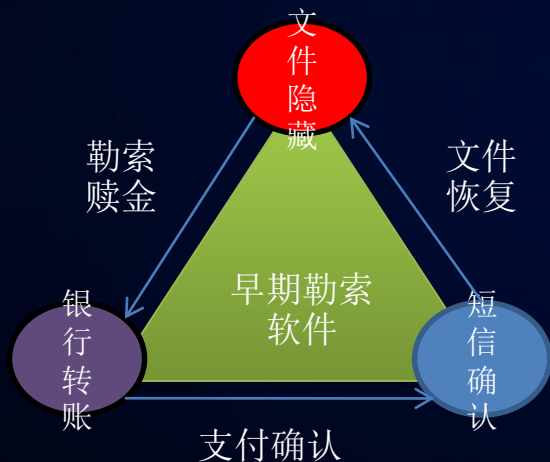
勒索软件的铁三角



作者欧阳某某于2007年在广州落网, 共借助Redplus木马勒索款项**95**笔, 合计人民币**7061.05**元。法院考虑到其自首情节, 最终判其有期徒刑**4**年。



2006年Redplus



勒索软件将借鉴以往的传播和感染技术

Locker v1.7

Information | **Payment** | Files | Status

Bitcions is a anonymous online payment system for more information see www.bitcion.com.
To obtain your decryption key you have to send 0.1 BTC to the bitcoin address listed below. You can buy bitcoins at;

- <https://www.coinbase.com>
- <https://www.localbitcoins.com>
- <https://www.bitstamp.net>

We recommend you to send the bitcoins to our wallet immediately and not store them in a local wallet since local wallets are encrypted by Locker v1.7

Payment address;

12E6vVFawrVK8Gd7Rk3whQqVodhGvuTHgg

ayment conformation usually takes about 1 hour. When we receive the payment the decryption key will automatically be send to the Locker software and start the decryption process.

Warning any attempt to remove damage or even investigate the Locker software will lead to immediate destruction of your private key on our server!



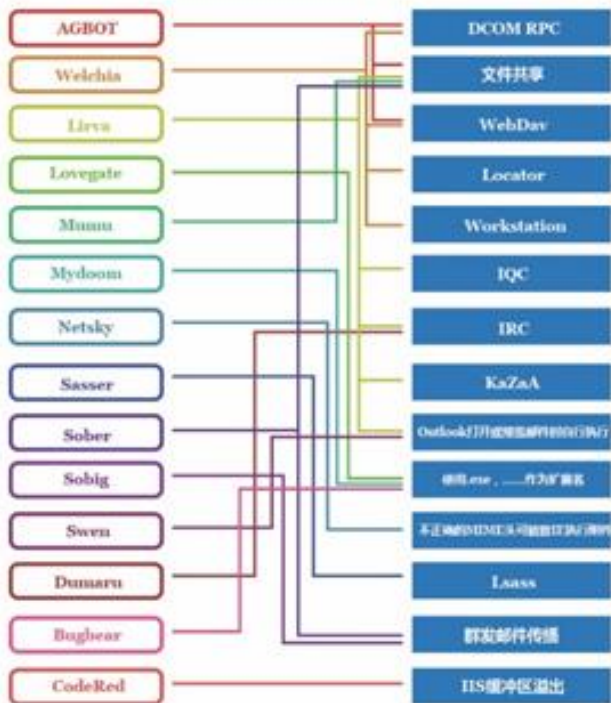
Time remaining:
69:55:45



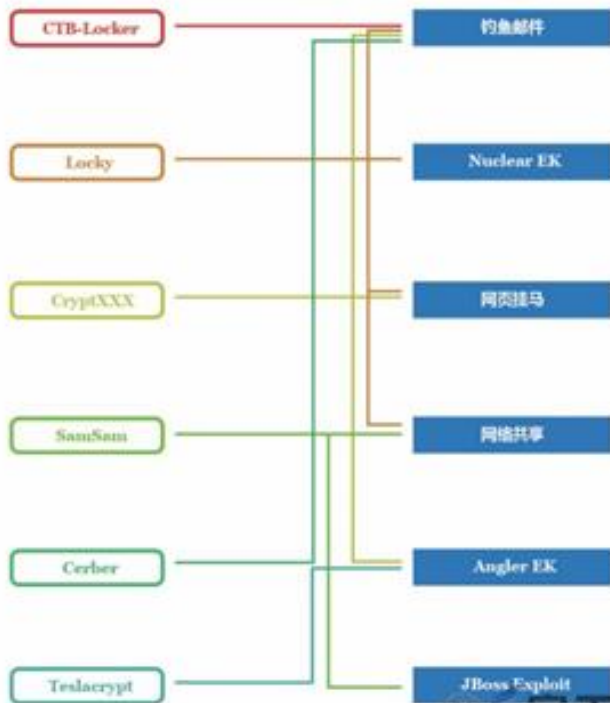
2015年5月底，勒索软件Locker作者公布密钥库，共包含**62,703**条记录，勒索金额按**0.1**比特币（当时约**175元**人民币）计算，收入高达**1097万元**人民币。

勒索软件会与蠕虫的传播模式相结合

蠕虫时代传播入口



勒索软件传播入口



需要警惕的勒索软件入口



安天对勒索病毒的持续跟踪

- ◆ 4月30日,《“攻击WPS”样本实为敲诈者》
- ◆ 8月3日,《揭开勒索软件的真面目》
- ◆ 12月4日,《邮件发送JS脚本传播敲诈者木马的分析报告》

2015 年

2016 年

- ◆ 1月17日,《2015年网络安全威胁的回顾与展望》
- ◆ 2月19日,《发现使首例具有中文提示的比特币勒索软件“LOCKY”》
- ◆ 12月20日,《2016网络安全威胁的回顾与展望》(安天基础威胁年报)

2017 年

- ◆ 4月,《勒索软件简史》(《中国信息安全》2017年第4期)
- ◆ 5月13日06:00发布《安天紧急应对新型“蠕虫”式勒索软件“WannaCry”全球爆发》
- ◆ 5月14日05:22更新《安天紧急应对新型“蠕虫”式勒索软件“WannaCry”全球爆发》

安天研究人员对此的补充观点是——比特币匿名支付和匿名网络带来的犯罪隐蔽性也是其中重要的原因。从后续来看,这种威胁会进一步复合化、与目前的黑产合流,走向更多的系统平台,采用更多的投放方式(而可能不再仅仅是尼日利亚王子式的垃圾邮件的群发),其灰色的配套服务也会更系统化。

——2016.09.07 《安天技术文章汇编第四卷第三分册.序言》
勒索模式带动的蠕虫的回潮不可避免。

——《2016安天基础威胁年报(预发布版)》, 2017.12.20

需要警惕的勒索软件入口



“魔窟” (WannaCry) 勒索蠕虫横扫全球

- 2017年5月12日20时左右，全球爆发大规模勒索软件感染事件，我国大量用户受到感染，文件被加密
- 蠕虫利用微软SMB漏洞MS17-010，由445端口传播
- 2017年4月14日黑客组织Shadow Brokers（影子经纪人）公开一批NSA使用的网络攻击工具，其中包含了该漏洞的利用程序
- 安天在2015年《一例针对中方机构的准APT攻击样本分析》报告提出：拥有全球最顶级能力的超级大国，对于有效控制网络攻击武器扩散，应该负起更多的责任
- 安天CERT在2017年4月14日发布的《2016年网络安全威胁的回顾与展望》预测：勒索模式带动的蠕虫的回潮不可避免



定性：一起高级网络军火的非受控使用事件

- **军用级别网络攻击武器扩散**：NSA军用网络攻击武器的泄露，为黑客提供了国家战略级网络武器，大大加强了恶意黑客组织的攻击能力，使黑客组织的攻击水平从组织级提升到了国家级。
- **暴露出来我国网络安全现状**：对物理隔离网络的盲目自信；恰恰是重要网络缺乏安全监测；终端防护成“重中之重”；常规防护措施无法应对“核弹”级武器；缺少专业团队的应急响应支撑



经济利益驱动



门槛日益降低



军用工具泄露



安全意识淡薄



防护措施不足

安天此前预判中的网络军火扩散

- 我们需要提醒各方关注的是，鉴于网络攻击技术所存在的极低的复制成本的特点，当前已经存在严峻的网络军备扩散风险……但对于缺少足够的安全预算、难以承担更多安全成本的国家、行业和机构来说，会成为一场噩梦。
- 在攻防两端均拥有全球最顶级能力的超级大国，对于有效控制这种武器级攻击手段的扩散，应该负起更多的责任。

——安天分析报告《一例针对中国政府机构的准APT攻击中所使用的样本分析》，2015.05.27

- 我们看到了相关的Exploit储备和攻击思路流入到网络犯罪组织、甚至恐怖主义组织的可能性。鉴于网络攻击技术存在极低的复制成本的特点，当前已经存在严峻的网络军备扩散风险。因此，超级大国能否合理控制自身网络军备发展的速度和规模，并对因自身未有效履行责任而使网络领域发生可能的军备扩散，进行有效地干预和控制，是我们能达成一个更安全的网络世界的关键因素。

——安天分析报告《从“方程式”到“方程组” EQUATION攻击组织高级恶意代码的全平台能力解析》，2016.10.04

安全厂商与时间赛跑

“WannaCry” 相关事件时间轴



安天启动A级（最高级）响应



做出威胁预测

- ◆ 安天在基础威胁年报中预测将在一年内爆发大规模勒索软件攻击，随后向CNCERT进行了专报。

第一时间通报处置

- ◆ 安天第一时间向主管部门通报勒索软件攻击事件，并协助制定和人员系统工作部署。
- ◆ 09:45 第一时间进行用户现场应急处置。
- ◆ 15:00-16:00 安天向客户发布勒索预警和防护手册。
- ◆ 17:00-18:00 发布《安天应对勒索软件“WannaCry”勒索病毒》。
- ◆ 发布《安天应对勒索病毒勒索病毒WannaCryQ2-1针对大量用户的漏洞扫描进行回查。

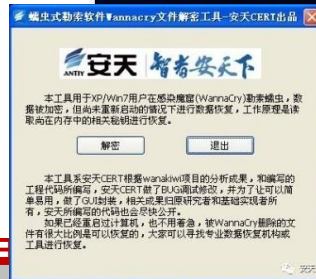
发布报告，推出工具

- ◆ 06:00 发布《安天应对勒索病毒“WannaCry”全球爆发深度分析报告》，报告公布一天突破31万浏览量。
- ◆ 15:00 发布勒索软件扫描工具（勒索工具、解密工具、查杀工具等），帮助用户进行勒索病毒扫描、查杀、解密、恢复。
- ◆ 16:00 安天发布勒索病毒扫描工具，帮助用户进行勒索病毒扫描、查杀、解密、恢复。
- ◆ 17:00-18:00 国家网络安全应急响应中心发布《关于勒索病毒“WannaCry”勒索病毒的公告》，要求各单位做好勒索病毒防范工作。
- ◆ 18:00-19:00 安天发布勒索病毒扫描工具，帮助用户进行勒索病毒扫描、查杀、解密、恢复。
- ◆ 19:00-20:00 安天发布勒索病毒扫描工具，帮助用户进行勒索病毒扫描、查杀、解密、恢复。
- ◆ 20:00-21:00 安天发布勒索病毒扫描工具，帮助用户进行勒索病毒扫描、查杀、解密、恢复。
- ◆ 21:00-22:00 安天发布勒索病毒扫描工具，帮助用户进行勒索病毒扫描、查杀、解密、恢复。
- ◆ 22:00-23:00 安天发布勒索病毒扫描工具，帮助用户进行勒索病毒扫描、查杀、解密、恢复。
- ◆ 23:00-24:00 安天发布勒索病毒扫描工具，帮助用户进行勒索病毒扫描、查杀、解密、恢复。

再次发布报告，提供扩展补丁包

- ◆ 15日00:20，安天发布“魔窟”勒索病毒内网应急响应工具。
- ◆ 15日08:00，针对部分用户提供扩展补丁包。
- ◆ 15日凌晨更新《安天应对勒索软件“WannaCry”开机指南》。
- ◆ 16日凌晨发布《对“魔窟”（WannaCry）勒索病毒变种情况分析》。

5:02 发布解密工具



启动A级响应



进驻用户现场



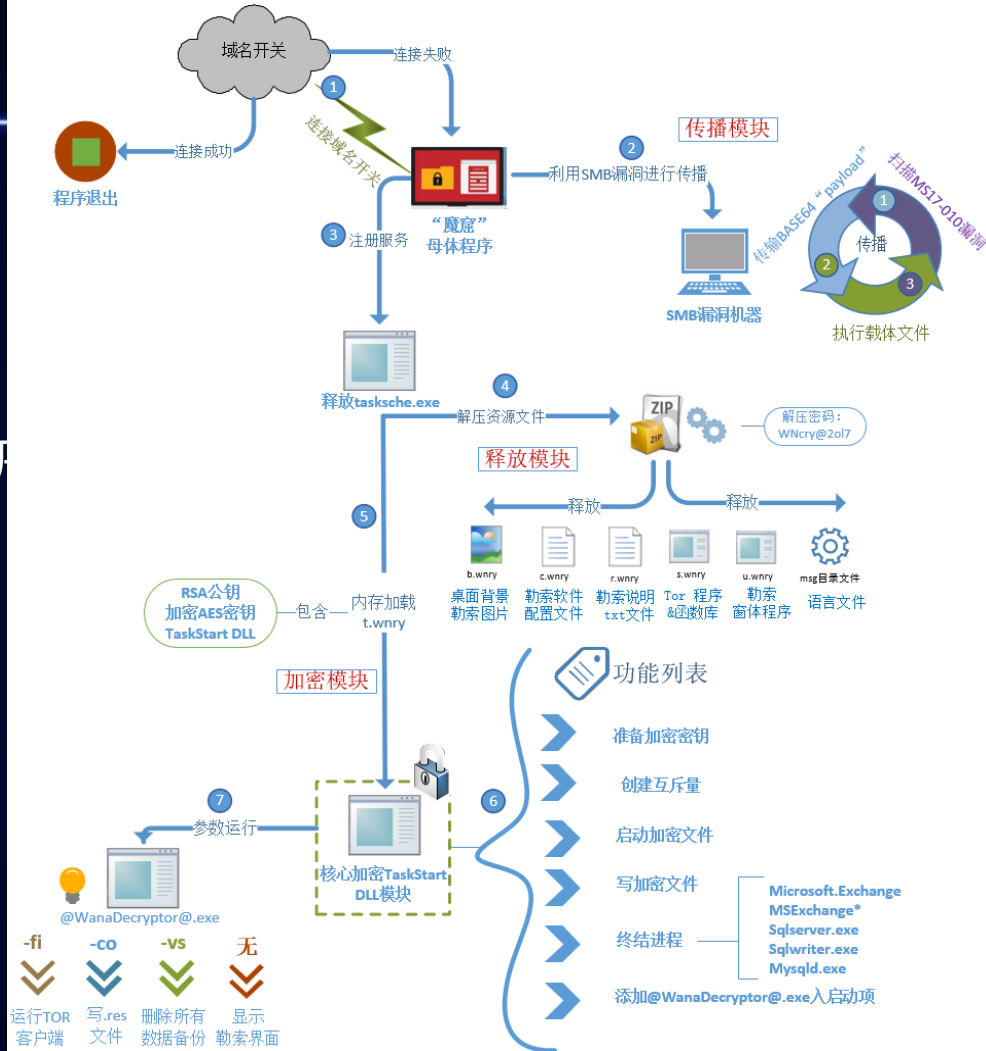
正式命名，更新工具



“魔窟” 运行流程

域名开关

- 添加服务、启动服务
 - 传播
- 释放、运行 “WannaCry” 勒索程序 (tasksche.exe)
 - 释放资源
 - 加密文件
 - 启动暗网
 - 显示勒索



内外网传播

- 判断内网IP段，遍历内网IP

```
1 int __cdecl InternalIPCheck(u_long hostlong)
2 {
3     u_long v1; // eax@1
4     int result; // eax@3
5
6     v1 = htonl(hostlong);
7     if ( v1 < 0xA0000000 || v1 > 0xAFFFFFFF ) // 10.0.0.0 ~ 10.255.255.255
8     {
9         if ( v1 < 0xAC100000 || v1 > 0xAC1FFFFFFF ) // 172.16.0.0 ~ 172.31.255.255
10            result = v1 >= 0xC0A80000 && v1 <= 0xC00AFFFF; // 192.168.0.0 ~ 192.168.255.255
11        else
12            result = 1;
13    }
14    else
15    {
16        result = 1;
17    }
18    return result;
19 }
```

- 外网IP随机算法生成

```
1 int __thiscall sub_407660(void *this)
2 {
3     int result; // eax@2
4     BYTE pbBuffer[4]; // [sp+0h] [bp-4h]@1
5
6     *(_DWORD *)pbBuffer = this;
7     if ( *(_DWORD *)&FileName[272] )
8     {
9         EnterCriticalSection(&CriticalSection);
10        CryptGenRandom(*(HCRYPTPROV *)&FileName[272], 4u, pbBuffer);
11        LeaveCriticalSection(&CriticalSection);
12        result = *(_DWORD *)pbBuffer;
13    }
14    else
15    {
16        result = rand();
17    }
18    return result;
19 }
```

mssecsvc.exe:1228 属性

映像性能性能图表线程TCP/IP安全性环境字符串

解析地址(R)

协议	本地地址	远程地址	状态
TCP	10.255.8.132...	58.131.118.173:445	SYN_SENT
TCP	10.255.8.132...	10.5.1.1:445	SYN_SENT
TCP	10.255.8.132...	88.138.130.174:445	SYN_SENT
TCP	10.255.8.132...	10.6.1.1:445	SYN_SENT
TCP	10.255.8.132...	8.166.58.150:445	SYN_SENT
TCP	10.255.8.132...	10.7.1.1:445	SYN_SENT
TCP	10.255.8.132...	143.36.163.61:445	SYN_SENT
TCP	10.255.8.132...	78.144.249.75:445	SYN_SENT
TCP	10.255.8.132...	16.26.1.237:445	SYN_SENT
TCP	10.255.8.132...	65.194.63.151:445	SYN_SENT
TCP	10.255.8.132...	10.8.1.1:445	SYN_SENT
TCP	10.255.8.132...	166.195.244.11:445	SYN_SENT
TCP	10.255.8.132...	88.79.218.108:445	SYN_SENT
TCP	10.255.8.132...	10.9.1.1:445	SYN_SENT
TCP	10.255.8.132...	10.10.1.1:445	SYN_SENT
TCP	10.255.8.132...	10.11.1.1:445	SYN_SENT
TCP	10.255.8.132...	10.12.1.1:445	SYN_SENT
TCP	10.255.8.132...	16.159.7.62:445	SYN_SENT
TCP	10.255.8.132...	50.134.39.48:445	SYN_SENT
TCP	10.255.8.132...	116.189.220.201...	SYN_SENT
TCP	10.255.8.132...	98.66.104.30:445	SYN_SENT
TCP	10.255.8.132...	10.13.1.1:445	SYN_SENT
TCP	10.255.8.132...	159.191.4.242:445	SYN_SENT
TCP	10.255.8.132...	10.14.1.1:445	SYN_SENT
TCP	10.255.8.132...	10.15.1.1:445	SYN_SENT
TCP	10.255.8.132...	10.16.1.1:445	SYN_SENT
TCP	10.255.8.132...	25.135.74.136:445	SYN_SENT
TCP	10.255.8.132...	10.17.1.1:445	SYN_SENT
TCP	10.255.8.132...	135.25.33.58:445	SYN_SENT

Process Explorer - Sysinter

文件(F) 选项(O) 查看(V) 进程(P) 帮助(H)

进程

进程	PID
系统空闲进程	0
中断	n/a
DPCs	n/a
System	4
smss.exe	568
csrss.exe	632
winlogon.exe	656
services.exe	700
vmacthlp.exe	876
svchost.exe	900
svchost.exe	1000
svchost.exe	1120
svchost.exe	1256
svchost.exe	1340
spoolsv.exe	1440
svchost.exe	1524
vmtoolsd.exe	1636
VMUpgradeH...	1724
mssecsvc.exe	1228
cmd.exe	1744
tasksche...	368
lsass.exe	712
explorer.exe	1948
VMwareTray.exe	472
VMwareUser.exe	480

创建线程利用SMB漏洞传播

```

60 v10 = s_GenerIP(v7) % 0xFFu;
61 v11 = s_GenerIP((void *)0xFF);
62 sprintf(&Dest, aD_D_D_D, v6, v19, v10, v11 % 0xFF); // 拼接IP地址
63 v12 = inet_addr(&Dest);
64 if ( sub_407480(v12) > 0 )
65     break;
66 LABEL_23:
67     Sleep(0x64u);
68 }
69 v17 = 0;
70 v18 = 0;
71 v21 = v1();
72 v13 = 1;
73 while ( 1 )
74 {
75     sprintf(&Dest, aD_D_D_D, v6, v19, v10, v13); // 拼接IP地址
76     v14 = inet_addr(&Dest);
77     if ( sub_407480(v14) <= 0 )
78         goto LABEL_20;
79     v15 = (void *)beginthreadex(0, 0, s_smb, v14, 0, 0); // 漏洞利用部分
80     v16 = v15;
81     if ( v15 )
82         break;

```

漏洞利用部分的代码

00 00 00 63 FF 53 4D 42 73 00 00 00 00 18 01 20	...C.SMBs.....
00 00 00 00 00 00 00 00 00 00 00 00 00 2F 4B	/K
00 00 C5 5E 0D FF 00 00 00 DF FF 02 00 01 00 00	
00 00 00 00 00 00 00 00 00 00 00 00 00 00 26	@...&
00 00 2E 00 57 69 6E 64 6F 77 73 20 32 30 30 30	Windows 2000
20 32 31 39 35 00 57 69 6E 64 6F 77 73 20 32 30	2195.Windows 20
30 30 20 35 2E 30 00 00 00 00 00 47 FF 53 4D 42	00 5.0.....G.SMB
75 00 00 00 00 18 01 20 00 00 00 00 00 00 00	u.....
00 00 00 00 00 00 2F 4B 5F 5F 55 53 45 52 49 44	/K__USERID
5F 5F 50 4C 41 43 45 48 4F 4C 44 45 52 5F 5F C5	__PLACEHOLDER__
5E 04 FF 00 00 00 00 00 01 00 1C 00 00 5F 5F 54	^.....T
52 45 45 50 41 54 48 5F 52 45 50 4C 41 43 45 5F	REEPATH_REPLACE
5F 3F 3F 3F 3F 3F 00 00 00 00 00 4A FF 53 4D 42	_?????.....J.SMB
25 00 00 00 00 18 01 28 00 00 00 00 00 00 00	%.....(.....
00 00 00 00 00 00 00 00 00 00 00 00 10 00 00 00	
00 FF FF FF FF 00 00 00 00 00 00 00 00 00 00	
00 4A 00 00 00 4A 00 02 00 23 00 00 00 07 00 5C	..J...J...#.....\
50 49 50 45 5C 00 00 00 00 00 00 85 FF 53 4D 42	PIPE\.....SMB
72 00 00 00 00 18 53 C0 00 00 00 00 00 00 00 00	r....S.....
00 00 00 00 00 00 FF FE 00 00 40 00 00 62 00 02	@...b...
50 43 20 4E 45 54 57 4F 52 4B 20 50 52 4F 47 52	PC NETWORK PROGR
41 4D 20 31 2E 30 00 02 4C 41 4E 4D 41 4E 31 2E	AM 1.0..LANMAN1.
30 00 02 57 69 6E 64 6F 77 73 20 66 6F 72 20 57	0..Windows for W
6F 72 6B 67 72 6F 75 70 73 20 33 2E 31 61 00 02	orkgroups 3.1a..
4C 4D 31 2E 32 58 30 30 32 00 02 4C 41 4E 4D 41	LM1.2X002..LANMA
4E 32 2E 31 00 02 4E 54 20 4C 4D 20 30 2E 31 32	N2.1..NT LM 0.12
00 00 00 00 00 00 00 88 FF 53 4D 42 73 00 00 00	SMBs...

硬编码SMB漏洞利用数据包

漏洞传播细节分析——Payload

```

0042E758 8B 44 24 04 60 89 C5 81 EC B4 00 00 00 89 E7 B8 .D$.`.....
0042E768 10 00 00 00 89 87 9C 00 00 00 B8 40 00 00 89 .....@....
0042E778 87 A0 00 00 00 B8 98 01 00 00 89 87 A4 00 00 00 .....
0042E788 B8 82 E9 43 85 89 87 A8 00 00 00 B8 00 00 00 00 ...C.....
0042E798 89 87 AC 00 00 00 B8 00 00 00 89 87 B0 00 00 00 .....
0042E7A8 00 B8 88 01 00 00 89 87 94 00 00 00 64 8B 1D 38 .....d..8
0042E7B8 00 00 00 66 8B 43 06 C1 E0 10 66 8B 03 66 25 00 ...f.C....f..f%.
0042E7C8 F0 8B 18 66 81 FB 4D 5A 74 07 2D 00 10 00 00 EB ...f..Mzt.-....
0042E7D8 F0 89 47 4C 89 C3 B9 94 01 69 E3 E8 8B 03 00 00 ..GL.....i....
0042E7E8 85 C0 0F 84 8A 02 00 00 89 07 B9 85 54 83 F0 E8 .....T...
0042E7F8 77 03 00 00 85 C0 0F 84 76 02 00 00 89 47 04 B9 w.....v....G..
0042E808 84 06 E7 F9 E8 62 03 00 00 85 C0 0F 84 61 02 00 .....b.....a..
0042E818 00 89 47 08 B9 F9 30 AC A4 E8 4D 03 00 00 85 C0 ..G...0...M....
0042E828 0F 84 4C 02 00 00 89 47 0C B9 AE B8 9F 5D E8 38 ..L....G.....].8

```

32位的shellcode

```

0042FA60 48 89 E0 66 83 E4 F0 41 57 41 56 41 55 41 54 53 H..f...AWAUUATS
0042FA70 51 52 55 57 56 50 50 E8 BC 06 00 00 48 89 C3 48 QRWUPP....H..H
0042FA80 B9 DF 81 14 3E 00 00 00 00 E8 26 05 00 00 48 85 ...>....&...H.
0042FA90 C0 0F 84 55 03 00 00 48 89 05 9C 07 00 00 48 B9 ...U...H.....H.
0042FAA0 BA 1E 03 A0 00 00 00 00 E8 07 05 00 00 48 85 C0 .....H..
0042FAB0 0F 84 36 03 00 00 48 89 05 85 07 00 00 48 B9 84 ..6...H.....H..
0042FAC0 06 E7 F9 FF FF FF FF E8 E8 04 00 00 48 85 C0 0F .....H...
0042FAD0 84 17 03 00 00 48 89 05 6E 07 00 00 48 B9 4F FE ....H..n...H.O.
0042FAE0 EB 15 00 00 00 00 E8 C9 04 00 00 48 85 C0 0F 84 .....H....
0042FAF0 F8 02 00 00 48 89 05 57 07 00 00 48 B9 F9 30 AC ...H..W...H..0.
0042FB00 A4 00 00 00 00 E8 AA 04 00 00 48 85 C0 0F 84 D9 .....H.....
0042FB10 02 00 00 48 89 05 40 07 00 00 48 B9 CA BE D0 EC ...H..@...H....
0042FB20 00 00 00 00 E8 8B 04 00 00 48 85 C0 0F 84 BA 02 .....H.....
0042FB30 00 00 48 89 05 29 07 00 00 48 B9 AE B8 9F 5D FF ..H..)....H....].

```

64位的shellcode

漏洞传播细节分析——DLL

```

0040B020 4D 5A 90 00 03 00 00 00 04 00 00 00 FF FF 00 00 MZ.....
0040B030 B8 00 00 00 00 00 00 00 40 00 00 00 00 00 00 .....@.....
0040B040 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 .....
0040B050 00 00 00 00 00 00 00 00 00 00 00 00 E0 00 00 .....
0040B060 0E 1F BA 0E 00 B4 09 CD 21 B8 01 4C CD 21 54 68 .....!..L.!Th
0040B070 69 73 20 70 72 6F 67 72 61 6D 20 63 61 6E 6E 6F is program canno
0040B080 74 20 62 65 20 72 75 6E 20 69 6E 20 44 4F 53 20 t be run in DOS
0040B090 6D 6F 64 65 2E 0D 0D 0A 24 00 00 00 00 00 00 mode....$.
0040B0A0 7D 9C 72 5F 39 FD 1C 0C 39 FD 1C 0C 39 FD 1C 0C }.r_9...9...9...
0040B0B0 D1 E2 16 0C 3D FD 1C 0C 39 FD 1D 0C 36 FD 1C 0C ....=...9...6...
0040B0C0 FA F2 41 0C 3A FD 1C 0C D1 E2 17 0C 38 FD 1C 0C ..A.:.....8...
0040B0D0 81 FB 1A 0C 38 FD 1C 0C D1 E2 18 0C 3A FD 1C 0C ....8.....:...
0040B0E0 52 69 63 68 39 FD 1C 0C 00 00 00 00 00 00 00 Rich9.....
    
```

32位的dll文件

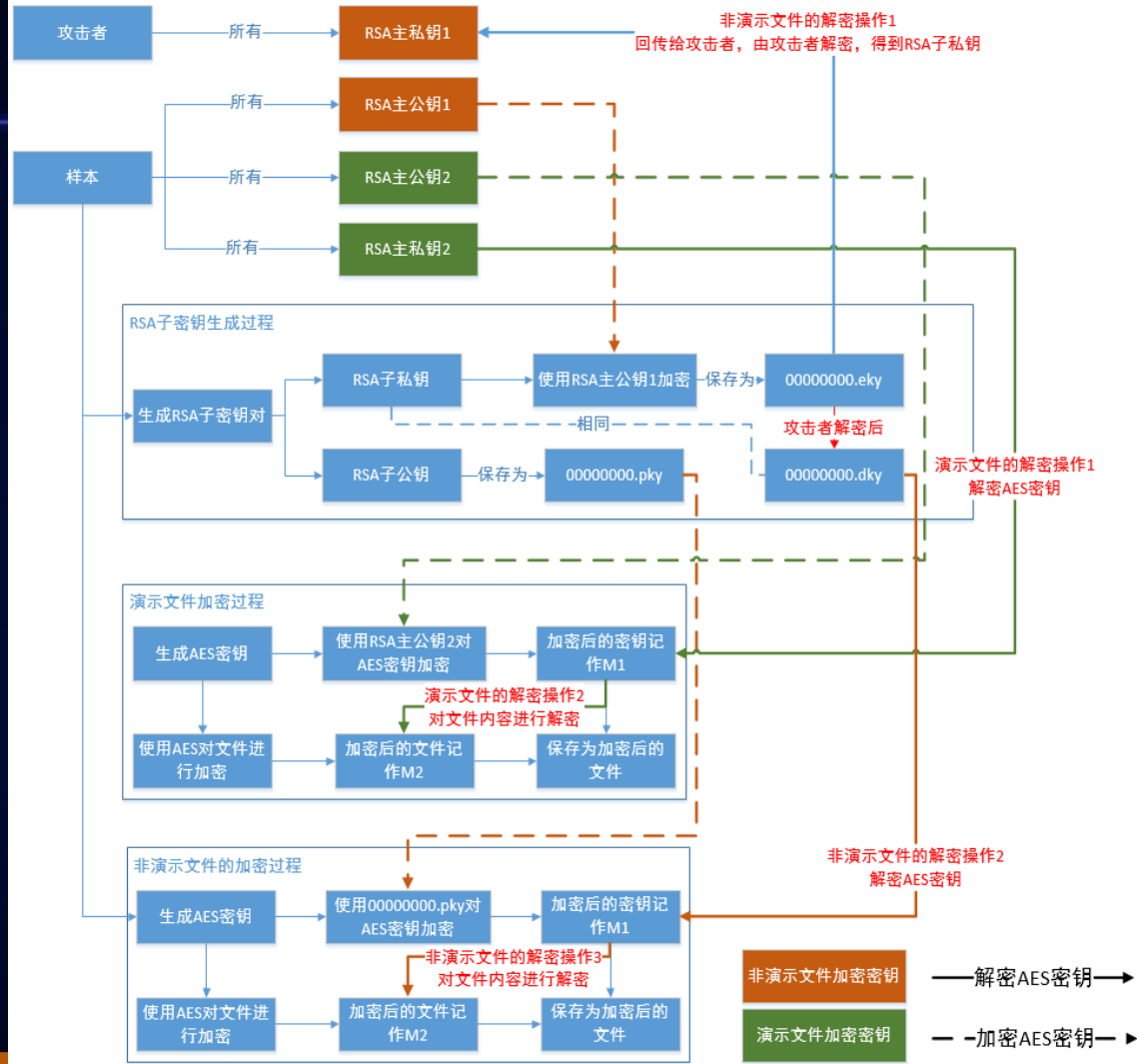
```

0040F080 4D 5A 90 00 03 00 00 00 04 00 00 00 FF FF 00 00 MZ.....
0040F090 B8 00 00 00 00 00 00 00 40 00 00 00 00 00 00 .....@.....
0040F0A0 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 .....
0040F0B0 00 00 00 00 00 00 00 00 00 00 00 00 E0 00 00 .....
0040F0C0 0E 1F BA 0E 00 B4 09 CD 21 B8 01 4C CD 21 54 68 .....!..L.!Th
0040F0D0 69 73 20 70 72 6F 67 72 61 6D 20 63 61 6E 6E 6F is program canno
0040F0E0 74 20 62 65 20 72 75 6E 20 69 6E 20 44 4F 53 20 t be run in DOS
0040F0F0 6D 6F 64 65 2E 0D 0D 0A 24 00 00 00 00 00 00 mode....$.
0040F100 6B 55 4B 17 2F 34 25 44 2F 34 25 44 2F 34 25 44 KUK./4%D/4%D/4%D
0040F110 34 A9 8F 44 7C 34 25 44 34 A9 B8 44 26 34 25 44 4..D|4%D4..D&4%D
0040F120 26 4C B6 44 2C 34 25 44 2F 34 24 44 7F 34 25 44 &L.D,4%D/4%D.4%D
0040F130 34 A9 8E 44 38 34 25 44 34 A9 BE 44 2E 34 25 44 4..D84%D4..D.4%D
0040F140 34 A9 BF 44 2E 34 25 44 34 A9 B8 44 2E 34 25 44 4..D.4%D4..D.4%D
0040F150 52 69 63 68 2F 34 25 44 00 00 00 00 00 00 00 Rich/4%D.....
    
```

64位的dll文件

加解密流程分析

- 服务器保存
 - 主RSA私钥1
 - 主RSA公钥1
 - 主RSA公钥2
 - 主RSA私钥2
- 样本内置
 - RSA子密钥对
 - AES密钥



“魔窟” 加解密流程

5.回传给攻击者

6.生成唯一比特币钱包，支付后解密



RSA 主私钥

RSA 主公钥

RSA 子公钥

RSA 子私钥

000000.pky

000000.eky

000000.dky

AES密钥

AES密钥

文件头

AES密钥

文件

文件

文件

000000.res

1.生成RSA子密钥对
(每次启动时)

2.生成AES密钥
(每次加密时)

3.加密终端文件

4.生成用户标识

加密

加密

加密

加密

解密



OFFSET	00	01	02	03	04	05	06	07	08	09	0A	0B	0C	0D	0E	0F	
00000000	57	41	4E	41	43	52	59	21	00	01	00	00	20	AE	A9	13	VANACRYT...
00000010	24	F8	F2	15	7B	01	8C	D4	8A	80	63	73	46	8C	EA	AA	Sà{ 101icsFie?
00000020	25	B4	C8	88	80	19	AF	4E	10	28	ED	C6	D3	3F	68	B3	%Eil'N.(ià07h?
00000030	AD	FC	EB	39	10	D8	AB	C1	EE	08	B9	F0	FF	27	79	07	-ue9.0ài.'8y'y
00000040	40	0C	76	3C	13	07	DF	09	A7	41	7A	5C	C7	74	F0	E8	@<v<.B.SàzCtàe
00000050	40	F9	07	FF	DF	98	47	3C	81	D6	A5	AC	EC	F3	68	ED	@àyB1G< 0w-ich1
00000060	AB	F6	0A	1C	68	FE	EF	80	4E	15	42	39	C6	19	86	8F	à.hpl1N.B9àI
00000070	D9	9A	B2	C4	F6	00	EF	85	E1	62	7C	58	87	0C	FC	88	U'à0.11àblX1.g1
00000080	8A	43	9E	79	16	2D	41	97	4B	FE	4A	FC	61	A4	D1	C7	IC1y-àAàE3àuàRàC
00000090	33	9E	1D	AE	DB	D3	20	75	4A	85	99	40	C6	C4	4A	55	31 800 w11à@AJU
000000A0	3A	86	A9	C1	07	08	0C	37	B2	F1	55	69	85	1D	5D	99	!0àA. ??Hu1.11
000000B0	0A	3F	50	24	45	44	08	DE	49	F2	F1	85	9F	BA	48	75	?PàED.11à011àHu
000000C0	AF	A4	DC	FA	DA	F3	C3	40	7D	11	4B	4A	49	59	46	31	=Uu0à@.KJ1YF1
000000D0	B8	49	B1	6E	CA	6D	4E	24	4B	58	43	4D	1F	DD	83	8F	!ànàNàK{CM.Y1
000000E0	95	D7	77	63	BF	52	98	2D	50	4B	04	C5	E4	0B	07	8E	!àvcàR1-FK.Aà.1
000000F0	DA	51	A4	D1	C2	4D	51	3A	79	89	7C	9D	69	B6	CB	13	UàNàQày111àE
00000100	E0	88	17	11	90	D9	C7	86	AB	78	3E	70	04	00	00	00	à.1. Uà1àx>p

显示新的比特币钱包地址



加解密时对文件的操作分析（可恢复性）

- 遍历查找指定后缀名文件
- 200MB以上单独标记单独处理
- 桌面、文档等重要目录文件擦写

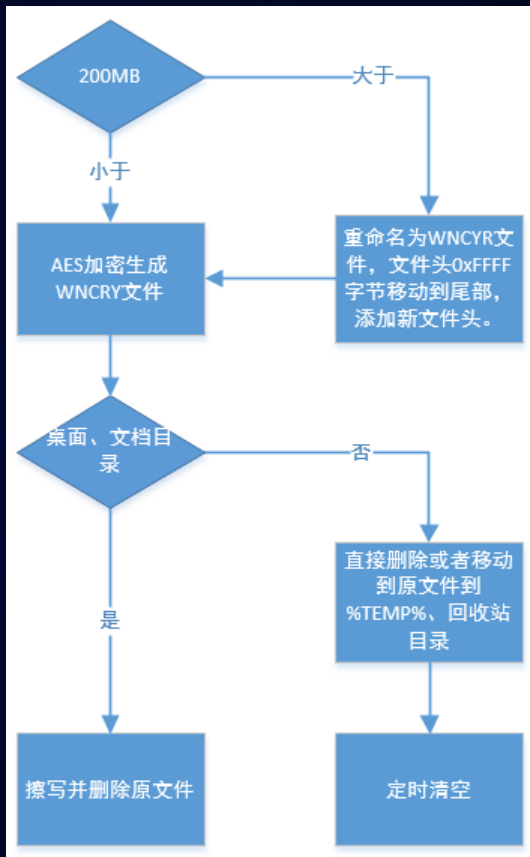
安天 AMT

安天针对勒索蠕虫“魔窟”（WannaCry）的深度分析报告（内部版）

每个被加密的文件均使用不同的 AES 密钥，若想对文件进行解密操作，需要先获取 RSA 子私钥，将文件头部的 AES 密钥进行解密操作，再使用 AES 密钥，对文件体进行解密操作。如果没有 RSA 子私钥，则 AES 密钥无法解密，文件也就无法解开。

加密如下后缀名的文件：

```
.doc .docx .xls .xlsx .ppt .pptx .pst .ost .msg .eml .vsd .vsdx .txt .csv .rtf .123 .wks .wk1 .pdf .dwa .onetoc2 .snt .jpeg .jpg .pg .docb .docm .dot .dotm .dotx .xism .xlsb .xlw .xlt .xlm .xlc .xltx .xltm .pptm .pot .pps .ppsm .ppsx .ppam .potx .potm .edb .hwp .602 .sxi .sti .sldx .sldm .vdi .vmdk .vmx .gpa .aes .ARC .PAQ .bz2 .tbk .bak .tar .taz .gz .7z .rar .zip .backup .iso .vcd .bmp .png .gif .raw .cam .tif .tiff .nef .psd .ai .svg .djuu .m4u .mid .wma .flv .3g2 .mkv .3gp .mp4 .mov .avi .asf .mpeg .vob .mpg .wmv .fla .swf .wav .mp3 .sh .class .jar .java .rb .asp .php .isp .brd .sch .dch .dip .pl .vb .vbs .ps1 .bat .cmd .js .asm .h .pas .cpp .c .cs .sua .sln .ldf .mdf .ibd .mvi .mvd .frm .odb .dbf .db .mdb .accd .b .sql .sqlitedb .sqlite3 .asc .lay6 .lay .mmi .sxm .ota .oda .uop .std .sxd .oto .odo .wb2 .slk .dif .stc .sxc .ots .ods .3d m .max .3ds .uot .stw .sxw .ott .odt .pem .p12 .csr .crt .key .plx .der
```



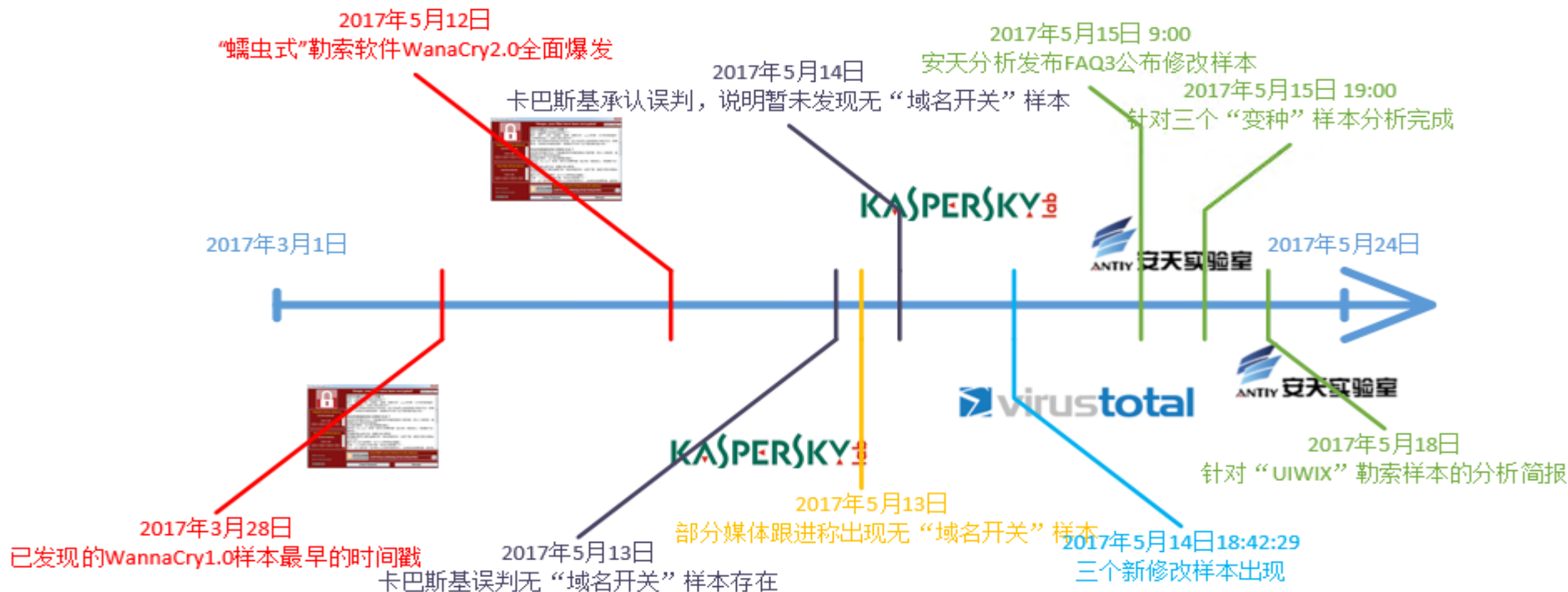
文件恢复条件判断

- 非桌面、文档、用户文件夹的文件
 - 磁盘空间充足，以保证被删除文件没被覆盖
 - %TEMP%目录、\$RECYCLE目录的.WNCRYT文件
 - 200MB以上文件恢复后需要将文件尾部0x10000字节剪切到文件头

 677.WNCRYT	2013-03-15, 星期...	WNCRYT 文件	1,435 KB
 624.WNCRYT	2008-08-08, 星期...	WNCRYT 文件	1,276 KB
 679.WNCRYT	2013-03-15, 星期...	WNCRYT 文件	1,259 KB
 869.WNCRYT	2009-01-04, 星期...	WNCRYT 文件	1,022 KB
 835.WNCRYT	2008-10-08, 星期...	WNCRYT 文件	563 KB
 682.WNCRYT	2013-03-15, 星期...	WNCRYT 文件	552 KB
 676.WNCRYT	2013-03-15, 星期...	WNCRYT 文件	489 KB
 871.WNCRYT	2013-01-08, 星期...	WNCRYT 文件	461 KB
 678.WNCRYT	2013-03-15, 星期...	WNCRYT 文件	455 KB

变种问题澄清 (5月15日)

“WannaCry” 变种事件时间轴



卡巴斯基承认误判，暂未发现“无域名开关的样本”

My bad - finished analyzing all [#Wannacry](#) worm mods we have and they all have the kill switch inside. No version without a kill-switch yet.

转推

272

喜欢

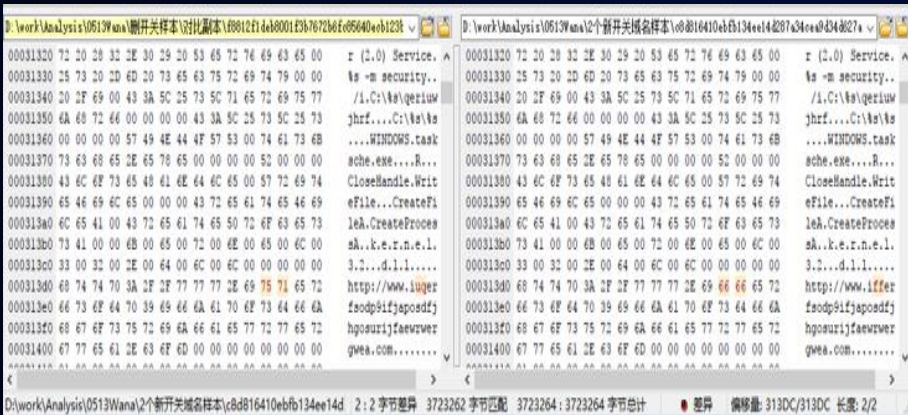
260



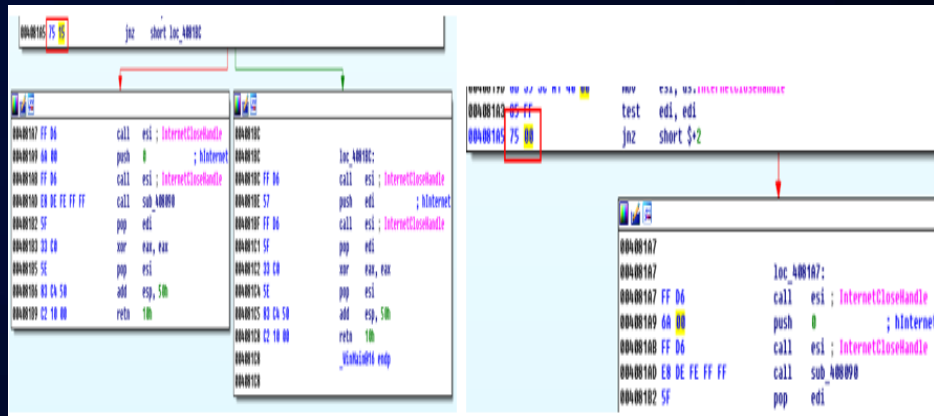
上午4:33 - 2017年5月14日

发现“变种样本”——修改样本对比

原始样本文件MD5	是否有加密行为	新发现的对应样本MD5	修改点
F107A717F76F4F910AE9CB4DC5290594（样本1）（资源损坏）	否	80CE983D22C6213F35867053BEC1C293（样本1A） D724D8CC6420F06E8A48752F0DA11C66（样本1B）	新域名 抹去域名开关，强制触发
DB349B97C37D22F5EA1D1841E3C89EB4（样本2）	是	D5DCD28612F4D6FFCA0CFEAEFD606BCF（样本2A）	新域名



修改域名



强制跳转

澄清“2.0版本”问题

- WannaCry1.0是一个单独的勒索程序，在2017年3月出现。
- WannaCry2.0是本次“魔窟”蠕虫使用的版本。

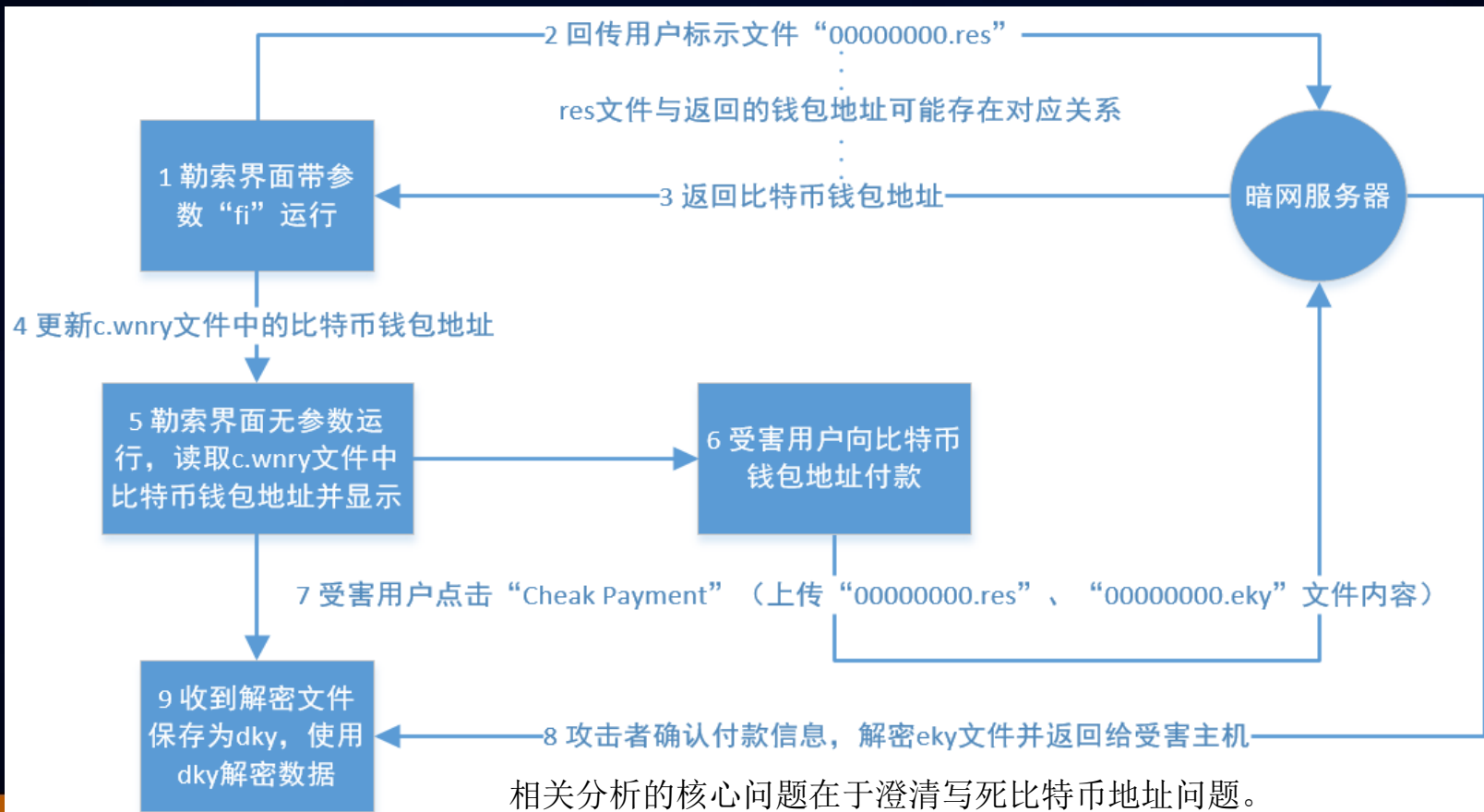


WannaCry 1.0



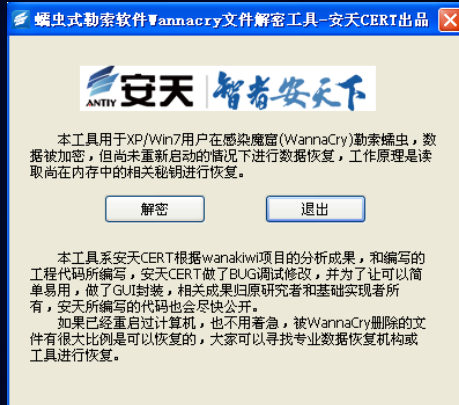
WannaCry 2.0

支付、解密流程（5月17日）

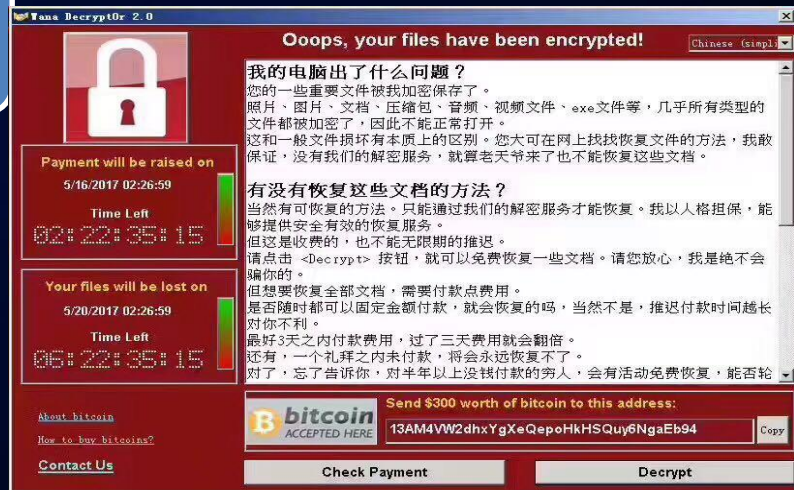
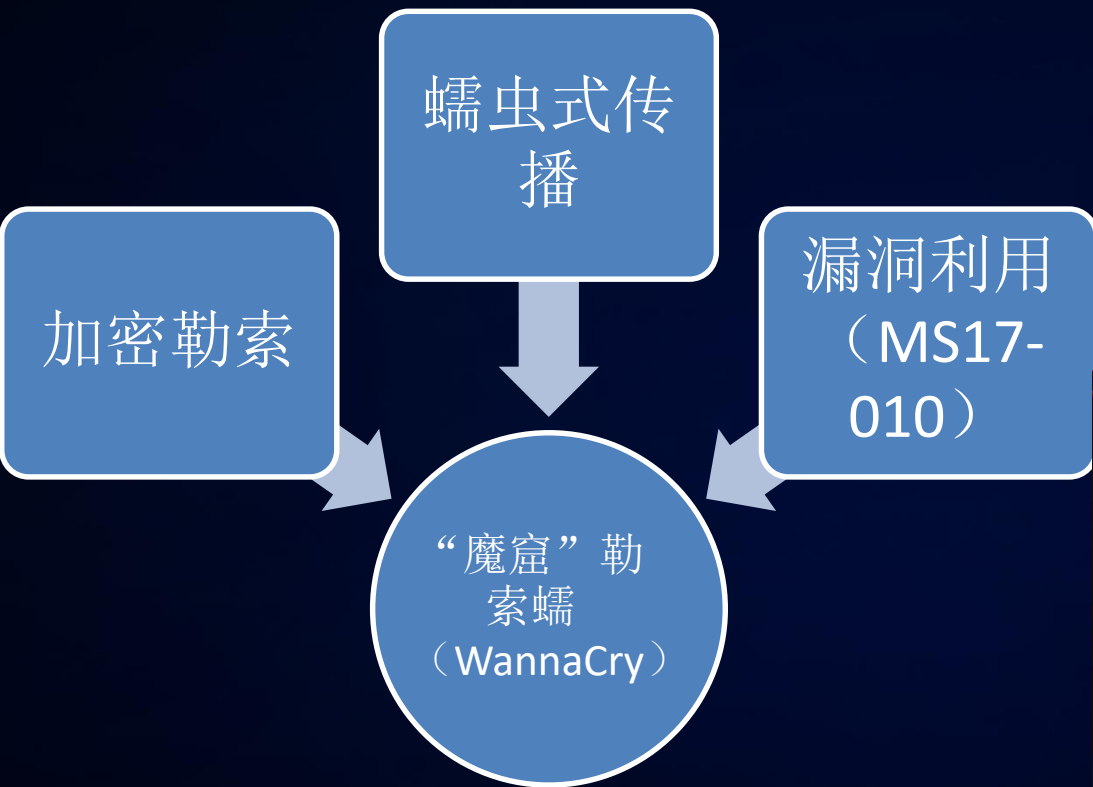


文件解密及安天工具

- 发现者
 - 由法国研究者发现并编写开源工程代码。
 - 此时体现了在解决问题的创造力和研究深度方面我们的差距。
- 原因
 - 微软CryptDestroyKey、CryptReleaseContext的问题导致生成的密钥的素数没有被销毁，可查找该素数生成密钥
 - XP、2003、WIN7 32位确认有效
- 条件
 - 感染后未重启机器，因为重启后内存清除
 - 未杀毒、专杀等，保证wannacry加密进程存在（tasksche.exe）



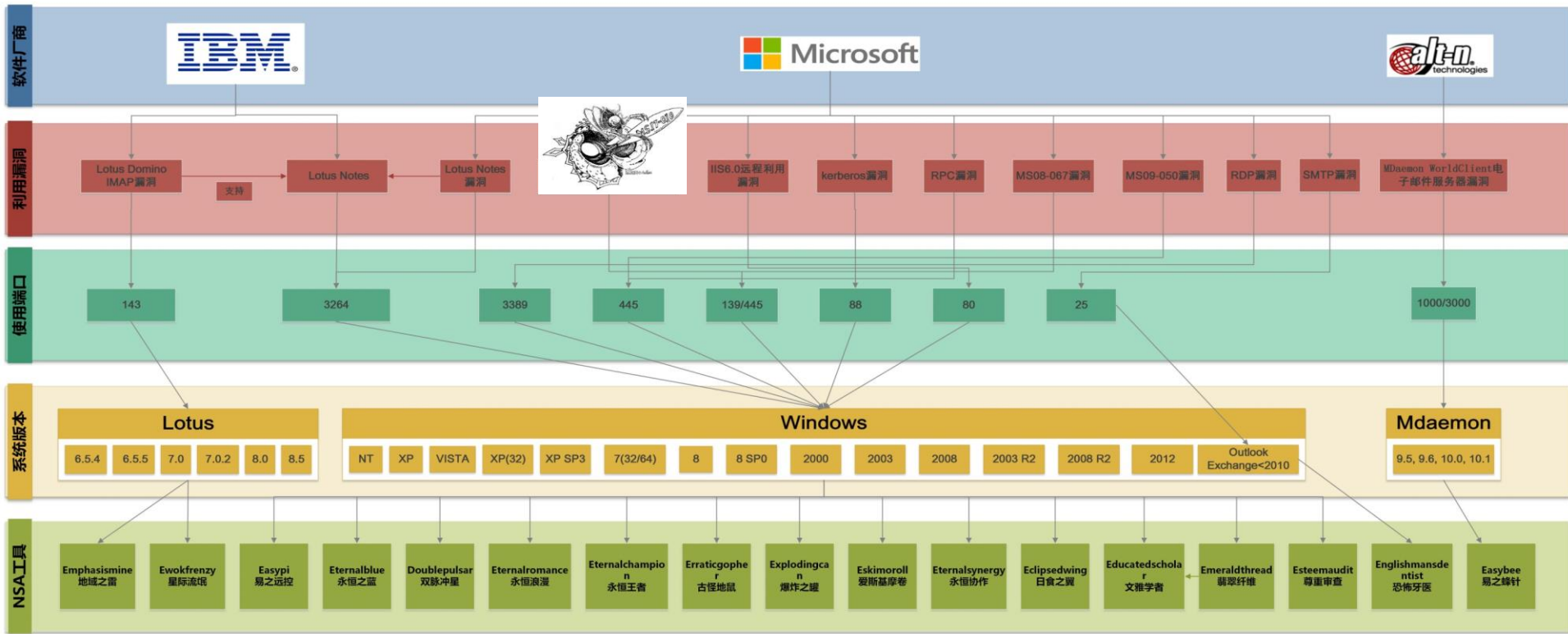
魔窟蠕虫的本质



“魔窟”只是冰山一角

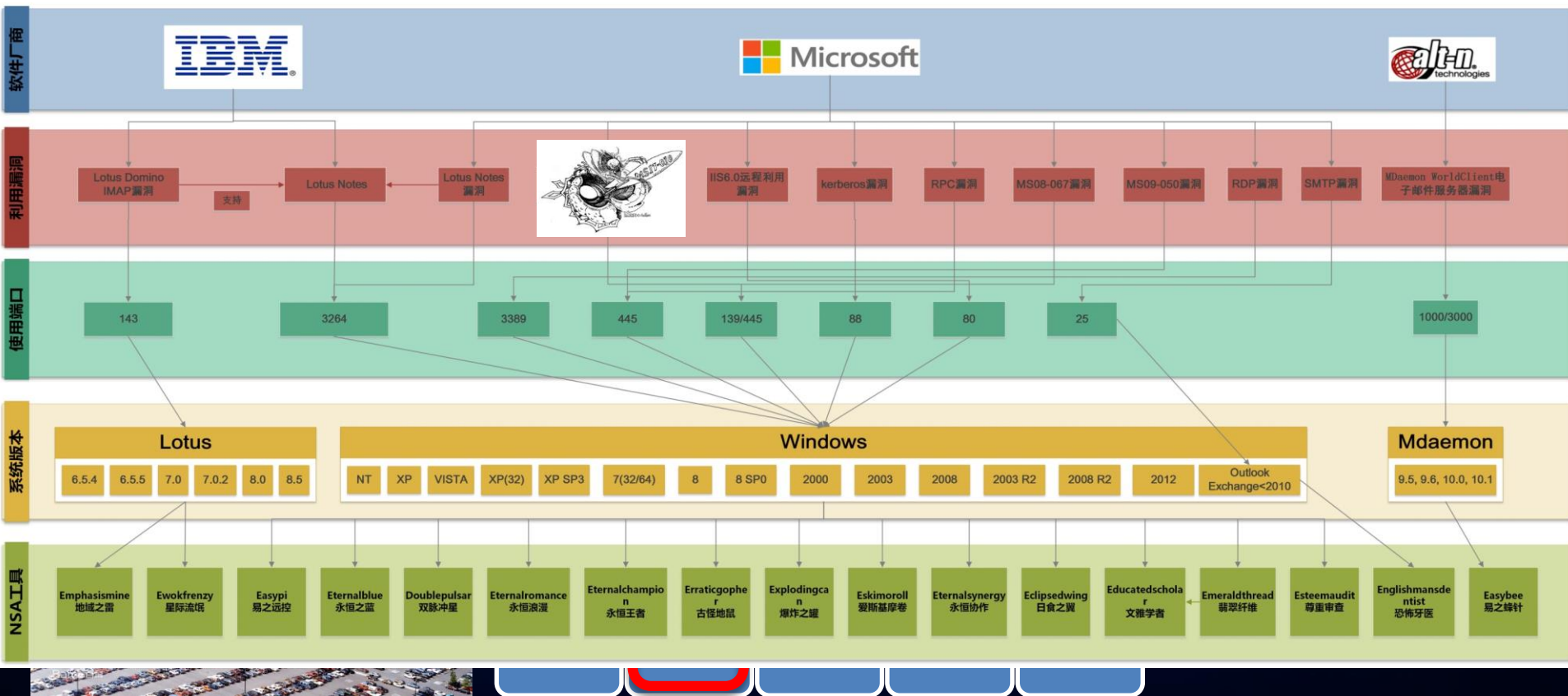
2017年4月14日泄露的NSA网络军火装备的漏洞利用关系图

2017年5月21日 安天实验室绘制



2017年4月14日泄露的NSA网络军火装备的漏洞利用关系图

2017年5月21日 安天实验室绘制



美国网络空间安全机构



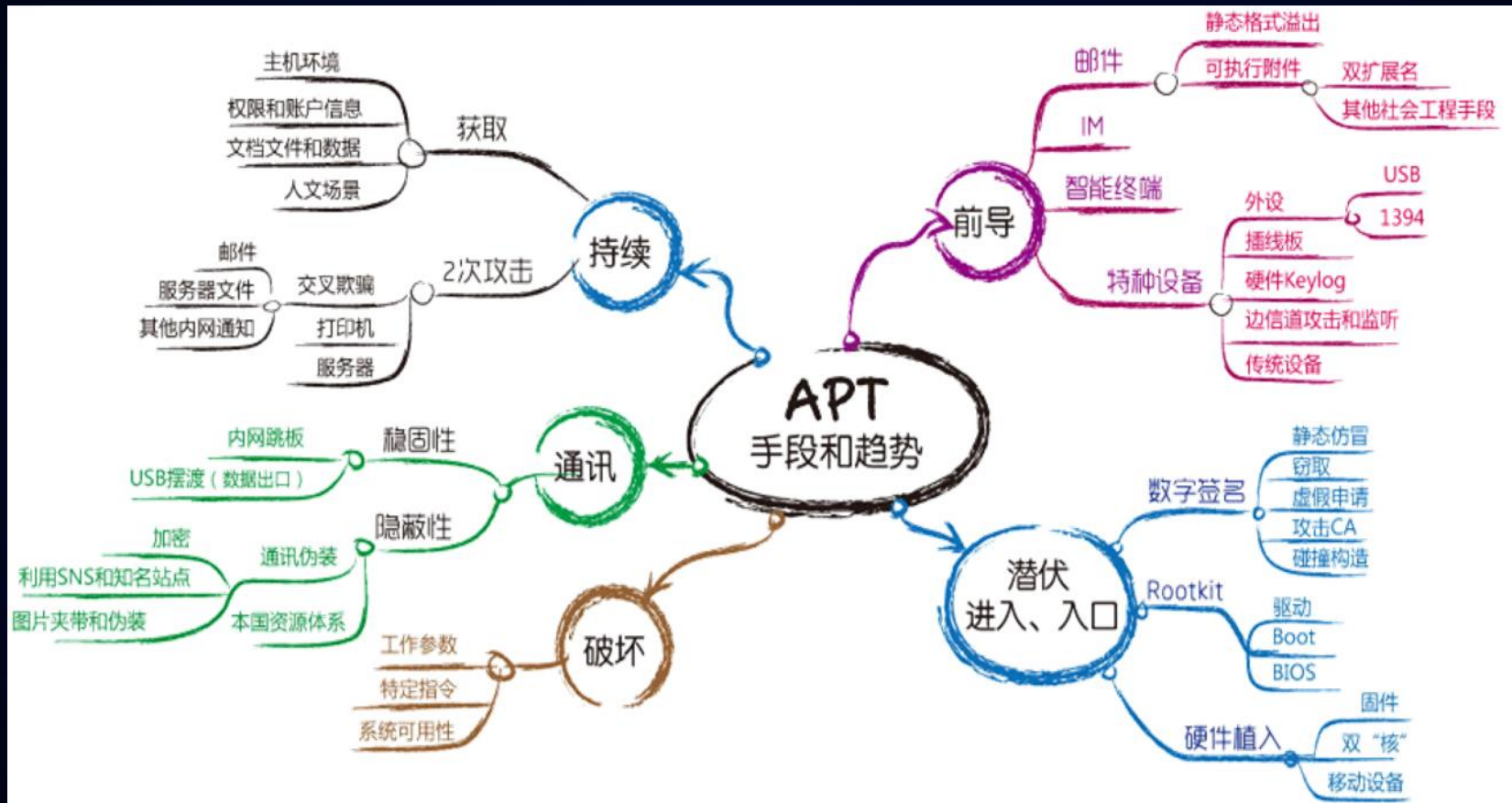
信息安全威胁成为本质性威胁（1977~2006）

	调谢利刃与巴比伦行动（传统物理攻击伊拉克核反应堆）	奥林匹斯行动（网络空间攻击伊朗）
合作攻击方	以色列、美国、伊朗（两伊战争）	美国、以色列
被攻击方	伊拉克（没有成熟的自主国防体系，视图从法国“买来”核能力）	伊朗（有相对成熟的工业体系）
时间周期	1977-1981年	2006-2010年
人员投入	以色列空军、特工人员、伊朗空军、美国空军和情报机构	美、以情报和军情领域的软件和网络专家，还有工业控制和核武器的专家
作业准备	多轮前期侦察和空袭，核反应堆情报	战场预制、病毒的传播和、伊朗核设施情报
各方装备投入	伊朗：2架F-4鬼怪式以12枚MK82减速炸弹-轰炸核反应堆假设工地； 10架F-4-袭击伊拉克H-3空军基地。 以色列：2架F-4E（S）-侦察任务；8架F-16A（美方提供）、4架F-15A、2架F-15B、16枚MK84炸弹-空袭反应堆 模拟搭建反应堆 特工人员暗杀伊拉克关键人员 美方：战略卫星和情报、空中加油机	美国： “震网”恶意代码 运维和控制体系 模拟搭建离心机和控制系统 以色列： “毒曲”恶意代码（环境采集准备）
效费比	打击快速，准备期长，耗资巨大、消耗大，行动复杂、风险高	周期长，耗资相对军事打击较低，但更加精准、隐蔽、不确定性后果更低
训练成本	18个月模拟空袭训练，2架F-4鬼怪攻击坠毁，3名飞行员阵亡。	跨越两位总统任期，经过了5年的持续开发和改进
消耗	人力、军力、财力、装备力、情报	人力、财力、情报
毁伤效果	反应堆被炸毁，吓阻了法国供应商，伊拉克核武器计划永久迟滞	导致1000台至2000台离心机瘫痪，铀无法满足武器要求，几乎永久性迟滞了伊朗核武器计划

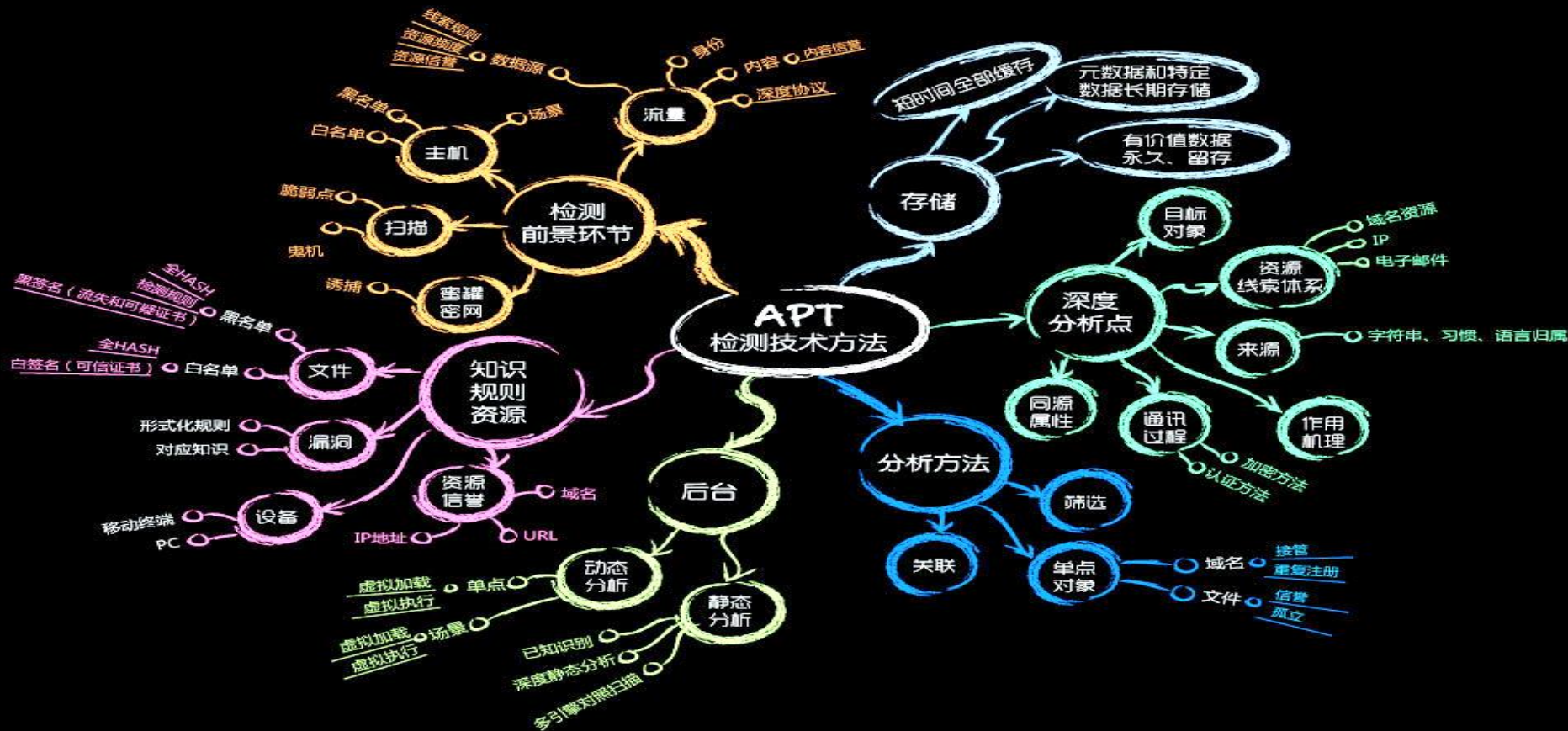
网络武器可以有许多适应环境的属性。从生命周期成本的角度来看，它们比其他武器系统更优越。这些系统都具有研究及开发成本，空间计划和传统平台也有很大的生产和部署成本，而网络武器的成本是最低的。网络和高空武器具有非常低的运营和维护成本，而传统武器系统的成本则是非常高的。总之，所有武器的成本曲线最初都是陡峭的，但是网络武器的下降速度最快，其次是空间武器，最后是传统平台。

——Maren Leed（美国陆军参谋长高级顾问）

高级持续威胁是攻击方法和技巧的集大成者



从方法对抗到体系对抗



在国家网络安全的层面，重视网络军火的非受控使用

1. 美国一方面无节制地提升网络攻击能力，但另一方面并没有有效履行相应的妥善管理相关武器国际义务，导致其军火级攻击平台、漏洞利用工具和恶意代码，以及攻击思路泄露。
2. 这些泄露的网络军火，已经开始危害全球基础互联网的安全。相对于传统武器而言，网络空间武器复制成本几乎为零，相对来说更容易失窃。
3. 超级大国需要承担妥善保管其网络军火的国际责任。

安天网络安全态势感知平台

系统运维支撑

权限管理

身份认证 权限管理
访问日志 安全审计

运维管理

设备配置 策略配置
运行监控 数据备份
系统日志 错误告警

时钟管理

时钟同步

升级管理维护

升级管理 版本记录

态势感知

数据综合
分析挖掘

掌握网络攻击情况
掌握自身网络安全隐患

安全监测

监测网络受
到的攻击威
胁

监测系统的
安全状况

追踪溯源

可视化
关联搜索

线索挖掘
与分析

通报预警

汇总、分析、研
判
威胁情报

威胁情况的
上报、通报、下
达

深度分析、关联挖掘与业务逻辑处理

样本深度分析
数据深度分析与回溯

可视化关联引擎
时间扩展字段索引服务

数据中心

样本文件库 安全威胁与事件库 IP/域名资源库 漏洞库 威胁情报库 资产库 其他库

事件与数据处理转化

数据下载与资源获取

URL库 下载URL管理

数据转化 事件、数据消重与合并 事件初始关联 预设条件比对标签化 日志泛化处理

标准日志 木马病毒传播 系统攻击 APT攻击

事件临时存储 事件与系统资源接收处理 事件与系统资源接收

非标准日志 日志汇编 标准日志 管道器 脚本 模板 非标准事件日志资源处理

二进制数据 二进制数据资源汇率 二进制数据资源处理

威胁信息采集

主机防御环节（智甲） 流量监测设备 扫描探测环节 蜜罐捕获设备

Thank you